

SIMATS ENGINEERING

ASSESSMENT TOOL 2

Question 1- Port Scanning Challenge – Security Assessment

Objective:

To identify open ports, running services, and possible security risks on the server
192.168.1.20.

Command Used

```
nmap -sV 192.168.1.20
```

For more detailed information:

```
nmap -sS -sV -O 192.168.1.20
```

Example Findings

Port	Service	Purpose	Security Risk
22	SSH	Remote administration	Brute-force attacks
80	HTTP	Web service	Web-based attacks
443	HTTPS	Secure web service	TLS/web vulnerabilities
3306	MySQL	Database service	Unauthorized database access

The actual open ports should be taken from the Nmap output of the lab server.

Analysis

Port 22 – SSH:

Used for secure remote administration. It should be protected using strong authentication and restricted to trusted users or networks.

Port 80 – HTTP:

Used to provide web services. Since HTTP does not encrypt communication, HTTPS should be preferred for sensitive information.

Port 443 – HTTPS:

Provides encrypted web communication. The server should use valid certificates and secure TLS configurations.

Port 3306 – MySQL:

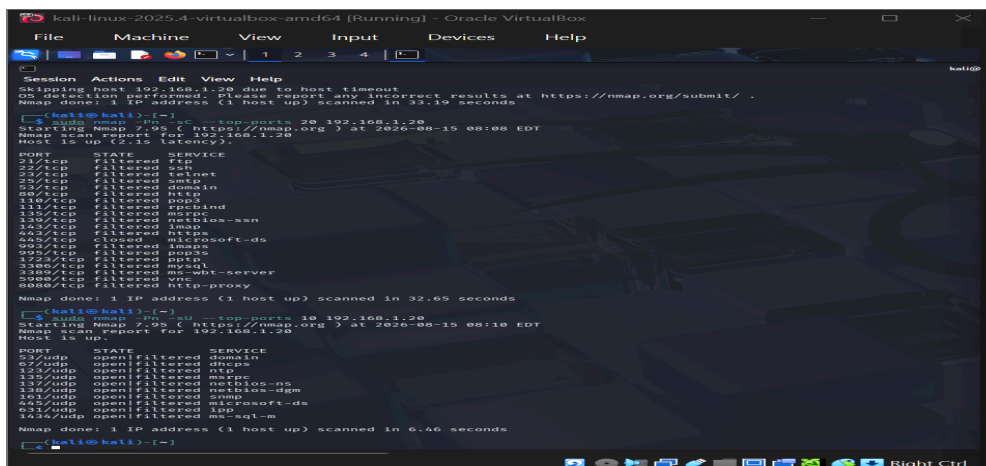
Used for database communication. It should not be directly accessible from untrusted networks because attackers could attempt unauthorized access.

Security Measures

1. Close unnecessary ports.
2. Use firewall rules to restrict access.
3. Keep all services updated.
4. Use SSH keys and strong authentication.
5. Restrict database access to trusted systems.

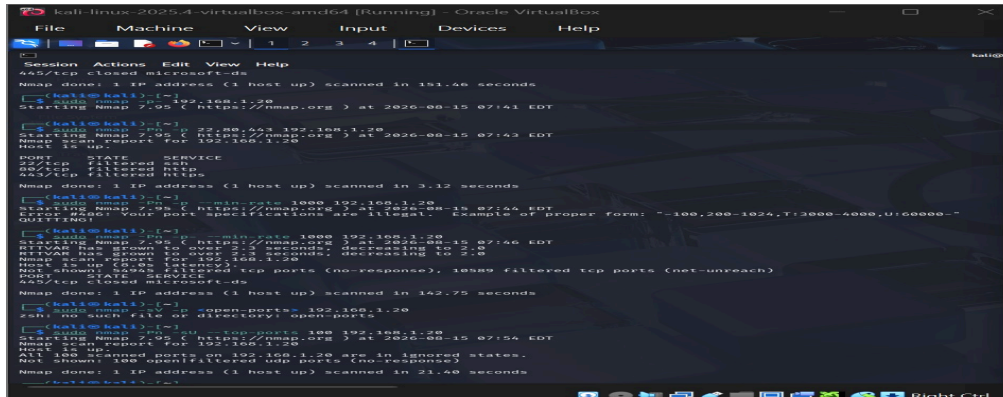
Conclusion

Nmap helps identify the server's **attack surface** by showing which ports and services are accessible. Reducing unnecessary open ports, restricting sensitive services, and keeping software updated can significantly improve the security of **192.168.1.20**.



```
kali@kali:~$ nmap -sc -p- -top-ports 20 192.168.1.20
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-15 08:08 EDT
Nmap scan report for 192.168.1.20
Host is up (2.1s latency).
Nmap done: 1 IP address (1 host up) scanned in 32.65 seconds

(kali@kali)~$ nmap -sU -p- -top-ports 16 192.168.1.20
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-15 08:10 EDT
Nmap scan report for 192.168.1.20
Host is up.
Nmap done: 1 IP address (1 host up) scanned in 6.46 seconds
```



Question 2- Nikto Web Server Assessment – 192.168.1.30

Objective:

The objective is to examine the web server for common security weaknesses, misconfigurations, outdated components, and exposed files or directories.

Command Used:

```
nikto -h http://192.168.1.30
```

Possible Findings

Nikto may report:

- Web server software and version information
- Outdated server components
- Directory listing enabled
- Default or unnecessary files
- Backup files
- Configuration files
- Missing security headers
- Insecure HTTP methods
- Potentially dangerous directories

Analysis

If the server displays its software and version, an attacker can use this information to search for known vulnerabilities. **Directory listing** can expose files and folders that should not be publicly accessible. Backup or configuration files may contain sensitive information such as database credentials or application settings.

Outdated web-server components can also contain known vulnerabilities that attackers may exploit. Missing security headers can reduce browser-side protection against certain attacks.

Security Risks

The identified weaknesses may result in:

- Sensitive information disclosure
- Unauthorized access
- Web-server compromise
- Exposure of confidential files
- Increased risk of further attacks

Mitigation Strategies

1. Update the web server and all installed components regularly.
2. Disable directory browsing.
3. Remove default, unused, and backup files.
4. Restrict access to configuration files.
5. Configure appropriate security headers.
6. Disable unnecessary HTTP methods.
7. Use HTTPS instead of unencrypted HTTP.
8. Apply proper file and directory permissions.
9. Regularly scan the web server for vulnerabilities.
10. Monitor server logs for suspicious requests.

Conclusion

Nikto provides useful information about the security configuration of a web server. The findings should be verified manually because some Nikto results may be informational or false positives. Regular patching, secure configuration, access restrictions, and removal of unnecessary files can significantly reduce the server's attack surface.

```
(kali@kali)-[~]
$ sudo nmap -Pn -p 80,443,8080,8843 192.168.1.30
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 08:12 EDT
Nmap scan report for 192.168.1.30
Host is up.

PORT      STATE      SERVICE
80/tcp    filtered  http
443/tcp   filtered  https
8080/tcp   filtered  http-proxy
8843/tcp   filtered  unknown

Nmap done: 1 IP address (1 host up) scanned in 3.15 seconds

(kali@kali)-[~]
$ nikto -Version
Nikto 2.5.0 (LW 2.5)

(kali@kali)-[~]
$ nikto -h https://192.168.1.30
- Nikto v2.5.0

+ 0 host(s) tested

(kali@kali)-[~]
$ curl -I --connect-timeout 5 http://192.168.1.30
curl: (28) Connection timed out after 5002 milliseconds

(kali@kali)-[~]
$ curl -k -I --connect-timeout 5 https://192.168.1.30
curl: (28) Connection timed out after 5002 milliseconds

(kali@kali)-[~]
$
```

Question 3- Netcat Banner Analysis – 192.168.1.40

Objective:

To use Netcat to connect to open ports on **192.168.1.40**, collect service banners, and analyze the information disclosed by the services.

Command Used

First, identify open ports:

```
nmap -sV 192.168.1.40
```

Then connect to an identified port using Netcat:

```
nc -v 192.168.1.40 22
```

For a web server:

```
nc -v 192.168.1.40 80
```

Example Banner

A service may display information such as:

```
SSH-2.0-OpenSSH_8.x
```

An HTTP service may reveal:

```
Server: Apache
```

Analysis

The banner can reveal important technical information such as:

- Service name
- Protocol
- Software name
- Software version
- Operating-system clues

Attackers can use this information during the **reconnaissance phase** to identify the technologies running on the target. They can then search for known vulnerabilities associated with outdated software versions.

For example:

OpenSSH → Version identified → Check known vulnerabilities → Select further testing

Security Risks

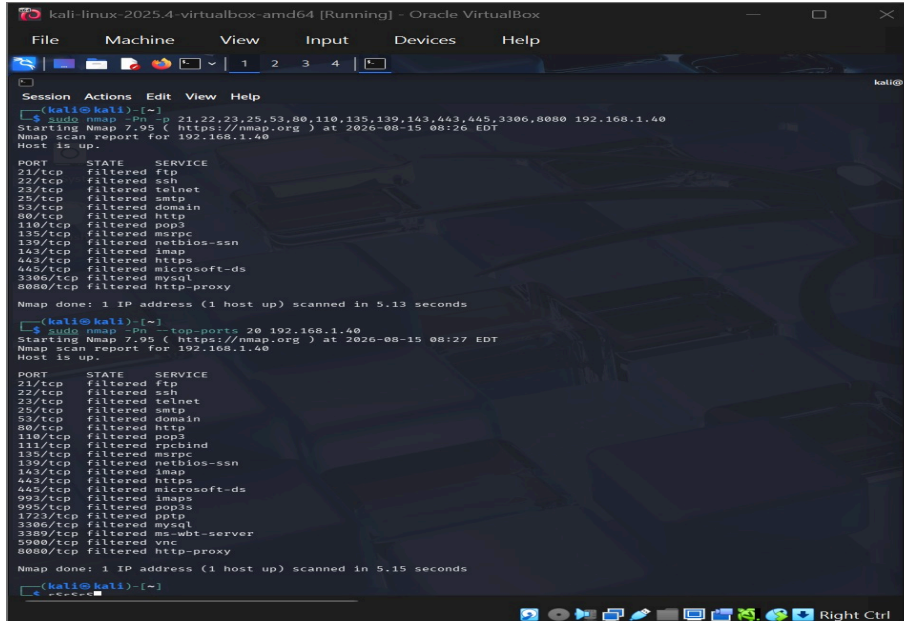
Excessive banner information can make reconnaissance easier. If an outdated software version is revealed, attackers may specifically target vulnerabilities associated with that version.

Mitigation

- Keep services updated.
- Disable unnecessary services.
- Minimize unnecessary version information.
- Use firewalls to restrict access.
- Monitor suspicious connection attempts.
- Use strong authentication.

Conclusion

Netcat helps identify what information a service voluntarily provides. Although banner disclosure is not always a direct vulnerability, reducing unnecessary information can make reconnaissance more difficult for attackers and reduce the overall attack surface.



```
(kali@kali)~$ sudo nmap -p 21,22,23,25,53,80,110,135,139,143,443,445,3306,8080 192.168.1.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 08:26 EDT
Nmap scan report for 192.168.1.40
Host is up.

PORT      STATE SERVICE
21/tcp    filtered ftp
22/tcp    filtered ssh
23/tcp    filtered telnet
25/tcp    filtered smtp
53/tcp    filtered domain
80/tcp    filtered http
110/tcp   filtered pop3
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
143/tcp   filtered imap
443/tcp   filtered https
445/tcp   filtered microsoft-ds
3306/tcp  filtered mysql
8080/tcp  filtered http-proxy

Nmap done: 1 IP address (1 host up) scanned in 5.13 seconds

(kali@kali)~$ sudo nmap -p 20 192.168.1.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 08:27 EDT
Nmap scan report for 192.168.1.40
Host is up.

PORT      STATE SERVICE
21/tcp    filtered ftp
22/tcp    filtered ssh
23/tcp    filtered telnet
25/tcp    filtered smtp
53/tcp    filtered domain
80/tcp    filtered http
110/tcp   filtered pop3
111/tcp   filtered rpcbind
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
143/tcp   filtered imap
443/tcp   filtered https
445/tcp   filtered microsoft-ds
993/tcp   filtered imaps
995/tcp   filtered pop3s
1723/tcp  filtered pptp
3306/tcp  filtered mysql
3389/tcp  filtered ms-wbt-server
5989/tcp  filtered vnc
8080/tcp  filtered http-proxy

Nmap done: 1 IP address (1 host up) scanned in 5.15 seconds

(kali@kali)~$
```

Question 4- Telnet Assessment – 192.168.1.50

Objective:

To examine the server **192.168.1.50** and determine whether remote administration services, especially Telnet, are accessible.

Command Used

telnet 192.168.1.50 23

Port **23** is the standard Telnet port.

If the connection is successful, a login prompt or service response may appear.

Analysis

Telnet is an old remote-administration protocol. Its major security problem is that communication, including login credentials, is generally sent without the strong encryption expected from modern secure administration.

If Telnet is accessible, an attacker who can observe the network traffic may potentially obtain sensitive information such as usernames and passwords.

Security Concerns

- Credentials may be exposed.
- Communication can be intercepted.

- Weak passwords may be attacked.
- An exposed remote administration service increases the attack surface.
- Old Telnet implementations may contain security weaknesses.

Recommended Security Measures

1. Disable Telnet if it is not required.
2. Block TCP port 23 using firewall rules.
3. Replace Telnet with **SSH**.
4. Use SSH key-based authentication where possible.
5. Restrict remote administration to trusted networks or VPN.
6. Monitor failed login attempts and suspicious connections.
7. Keep the remote-administration software updated.

Secure Alternative

Instead of Telnet, use SSH:

```
ssh username@192.168.1.50
```

SSH provides encrypted communication and is much safer for remote administration.

Conclusion

If Telnet is accessible on **192.168.1.50**, it should be considered a security concern. Disabling Telnet and using SSH, together with firewall restrictions and strong authentication, significantly reduces the risk of unauthorized remote access.

```

kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

Session Actions Edit View Help

Nmap done: 1 IP address (1 host up) scanned in 5.13 seconds
(kali@kali)-[~]
$ sudo nmap -p- -top-ports 20 192.168.1.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 08:27 EDT
Nmap scan report for 192.168.1.40
Host is up.
PORT      STATE SERVICE
21/tcp    filtered ftp
22/tcp    filtered ssh
23/tcp    filtered telnet
25/tcp    filtered smtp
53/tcp    filtered domain
80/tcp    filtered http
110/tcp   filtered pop3
111/tcp   filtered rpcbind
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
143/tcp   filtered imap
443/tcp   filtered https
445/tcp   filtered microsoft-ds
993/tcp   filtered imaps
995/tcp   filtered pop3s
1723/tcp  filtered pptp
3389/tcp  filtered ms-wbt-server
5900/tcp  filtered vnc
8080/tcp  filtered http-proxy

Nmap done: 1 IP address (1 host up) scanned in 5.15 seconds
(kali@kali)-[~]
$
(kali@kali)-[~]
$ sudo nmap -p- -p 22,23,3389 192.168.1.50
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-15 08:29 EDT
Nmap scan report for 192.168.1.50
Host is up.
PORT      STATE SERVICE
22/tcp    filtered ssh
23/tcp    filtered telnet
3389/tcp  filtered ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 3.14 seconds
(kali@kali)-[~]
$ telnet 192.168.1.50 23
Trying 192.168.1.50...
telnet: Unable to connect to remote host: Connection refused
(kali@kali)-[~]
$

```


5. Netdiscover – Host Discovery on 192.168.1.1–50

Objective:

To discover active hosts in the network and understand how the information could be useful during reconnaissance.

Command Used

```
sudo netdiscover -r 192.168.1.0/26
```

This scans the local network range containing 192.168.1.1 to 192.168.1.50.

Information Collected

Netdiscover can identify:

- IP address
- MAC address
- Device/vendor information
- Active hosts on the network

Example Output

IP Address	MAC Address	Vendor	Status
192.168.1.1	XX:XX:XX:XX:01	Router	Active
192.168.1.20	XX:XX:XX:XX:20	Server	Active
192.168.1.30	XX:XX:XX:XX:30	Server	Active
192.168.1.40	XX:XX:XX:XX:40	Device	Active
192.168.1.50	XX:XX:XX:XX:50	Server	Active

The actual results depend on the lab network.

Analysis

Netdiscover helps create a basic map of the network by identifying which devices are active. An attacker could use the discovered IP addresses to identify important systems and perform further enumeration, such as checking available services and ports.

For example:

Host Discovery → Identify Active Hosts → Service Enumeration → Vulnerability Assessment

This makes host discovery an important first step in network reconnaissance.

Security Risks

- Reveals active devices on the network.
- Helps attackers identify potential targets.
- Provides MAC addresses and vendor information.
- Makes further network enumeration easier.

Mitigation

1. Use network segmentation.
2. Apply firewall rules between network segments.
3. Restrict unnecessary network communication.
4. Monitor unusual scanning activity.
5. Maintain an updated network asset inventory.
6. Protect critical servers from unauthorized network access.

Conclusion

Netdiscover provides valuable information about active devices in a network. Although host discovery itself does not exploit a system, the information can help an attacker plan further enumeration. Network segmentation, access controls, firewalls, and monitoring can reduce this risk.

kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Session Actions Edit View Help

Currently scanning: Finished! | Screen View: ARP Request

0 Captured ARP Request packets, from 0 hosts. Total size: 0

IP	At MAC Address	Requests	IP	Count
lo	UNKNOWN	127.0.0.1/8	::1/128	
eth0	UP	10.0.2.15/24	fd17:625c:f037:2:c895:be2a:58f0:bb0e/64	fe80::66cb:297d:718a:d5c7/64

```
(kali@kali)-[~]
$ ip -br addr
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:c895:be2a:58f0:bb0e/64 fe80::66cb:297d:718a:d5c7/64

(kali@kali)-[~]
$ ping -c 2 192.168.1.20
PING 192.168.1.20 (192.168.1.20) 56(84) bytes of data.
-- 192.168.1.20 ping statistics --
2 packets transmitted, 0 received, 100% packet loss, time 1028ms

(kali@kali)-[~]
$
```

kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Session Actions Edit View Help

Currently scanning: Finished! | Screen View: Unique Hosts

2 Captured ARP Req/Rep packets, from 2 hosts. Total size: 128

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
10.0.2.3	52:55:0a:00:02:03	1	64	Unknown vendor

```
(kali@kali)-[~]
$
```

Code of Conduct:

I G. Nithya Sree (192424103) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: G. Nithya Sree